

Choisir comment évaluer les LLM en cybersécurité

Alternance : veille, sélection de benchmarks et application d'évaluation.

BESOIN

Évaluer les modèles selon les usages cyber de l'entreprise et leurs performances.

VEILLE / SÉLECTION

Environ 10 benchmarks examinés.
Open source ou utilisables gratuitement.
Critères de scoring, adaptation et licence.

MISE EN ŒUVRE

Application de benchmark cyber et performance.
Scores et métriques enregistrés en base.

Distinguer sélection du dispositif d'évaluation et sélection du modèle.

Évaluer la pertinence et les contraintes d'usage

Deux dimensions complémentaires de l'évaluation.

CAPACITÉS CYBER

Mesurer les modèles sur des tâches en lien avec les usages réels de l'entreprise.

PERFORMANCE

P50, P95, P99.
Vitesse et concurrence.
Définir la charge et les conditions de mesure.

DÉCISION

Comparer les résultats aux contraintes métier.
Modèles évalués et recommandation finale à documenter.

Un score cyber élevé ne suffit pas si le service ne tient pas la charge requise.

Sélectionner des évaluations adaptées

Critères de sélection explicitement indiqués par le candidat.

SCORING

Exclure LLM-as-judge.
Exclure human-as-judge pour le calcul des scores.
Montrer le mécanisme retenu.

PERTINENCE

Adaptabilité aux usages cyber réels de l'entreprise.
Périmètre et limites des tâches à préciser.

ACCÈS / LICENCE

Open source ou usage gratuit.
Compatibilité de licence étudiée.
Gratuité et droits de réutilisation distingués.

Un score sans juge reste à examiner pour sa validité et ses biais.

Environ dix benchmarks cyber étudiés

Une recherche comparative orientée vers un besoin d'entreprise.

RECENSER

Identifier les benchmarks ouverts ou utilisables gratuitement.
Conserver les sources et versions consultées.

ANALYSER

Comparer scoring, pertinence métier, adaptabilité et licence.
Expliciter les exclusions.

RESTITUER

Joindre la matrice de comparaison et la synthèse.
Préciser dates, rythme de veille et partage réel.

L'étude est réalisée ; son organisation régulière et sa diffusion restent à documenter.

Un modèle exécuté, un runner extensible

Modèle de la famille Qwen ; référence exacte à confirmer.

EXÉCUTION

Un seul modèle disponible dans l'architecture entreprise a été exploité à ce stade.
Preuves de runs disponibles.

CONCEPTION

Script conçu pour être agnostique des modèles et des benchmarks cyber.
Interfaces de configuration à montrer.

LIMITE C7

Pas encore de comparaison empirique entre plusieurs modèles.
Distinguer contrainte d'architecture et recommandation de service.

L'extensibilité du runner n'est pas une comparaison multi-modèles déjà réalisée.

Une génération hébergée, un RAG local

Décision d'architecture déjà documentée dans le projet.

GÉNÉRER

Service OpenAI-compatible



Narration, choix et décisions

Modèle piloté par configuration.

RETROUVER

JSON de lore → fragments



Embeddings Ollama → Chroma



Contexte filtré par aventure.

ORCHESTRER

LangGraph



Transitions explicites



Outils et moteur de jeu.

Localiser les embeddings ne signifie pas que le contexte reste entièrement local.

Rendre la configuration explicite

Valeurs par défaut du code ; l'environnement peut les remplacer.

GÉNÉRATION

Modèle : OPENAI_MODEL.
Clé dans l'environnement.
Timeout d'appel : 30 s.
Métadonnées sans clé secrète.

RETRIEVAL

RAG_ENABLED configurable.
Ollama : hôte local par défaut.
Embeddings : mxbai-embed-large.
Timeout : 10 s ; 3 tentatives.

FRONTIÈRE API

Choix : 1 000 caractères max.
Quota par défaut : 20 tours par utilisateur et par heure.
Validation de configuration.

Les paramètres décrivent le déploiement ; les secrets restent hors des supports.

Préparer le contexte avant la génération

Vérification locale du corpus : 57 fragments préparés.

CORPUS

6 fichiers de personnages.
3 fichiers de lieux.
57 fragments au dry-run.
Métadonnées de source.

À L'EXÉCUTION

Requête contextualisée.
Recherche filtrée par aventure.
Passages injectés au prompt.
Cache selon le service.

EN CAS D'ÉCHEC

Contexte vide et poursuite du jeu.
Échec visible dans les métriques.
Qualité narrative à surveiller.

Le dry-run vérifie la préparation ; il ne mesure ni les embeddings ni le rappel du RAG.

Conserver et interpréter chaque campagne

Un modèle exécuté ; cyber et performance mesurés par le même outil.

RÉSULTATS

Scores de benchmarks cyber.
P50 / P95 / P99.
Vitesse et concurrence.
Enregistrement en BDD.

RUNNER AGNOSTIQUE

Prise en compte de différents
modèles et benchmarks prévue par
conception.
Montrer l'interface de configuration.

PREUVES À JOINDRE

Référence Qwen confirmée.
Une campagne réelle.
Conditions, unités et erreurs.
Schéma des résultats stockés.

Présenter les scores du modèle disponible, sans fabriquer de classement.

Une veille concrète et un outil d'évaluation opérationnel

La comparaison porte aujourd'hui sur les benchmarks, pas encore sur plusieurs modèles.

C6

Environ dix benchmarks étudiés.
Scoring, usage et licences comparés.
Matrice et traces de partage à joindre.

C7

Un modèle imposé par sa disponibilité.
Comparaison et recommandation de services encore à étayer.

C8

Configuration du jeu en complément.
Joindre l'environnement et la référence exacte du modèle entreprise.

Le point fort nouveau est C12 ; la limite de comparaison C7 reste explicite.

Intégration et évaluation : des preuves complémentaires

Trois contextes identifiés, sans fusion artificielle de leurs architectures.

CALL TO ADVENTURE

API du jeu et intégration IA.
Contrôles d'accès, métriques et workflow existants.

ANALYSTE CYBER

Application Django et agent LLM.
Contribution personnelle : quatre stories Tines fournissant des données EDR.

ÉVALUATION

Application de benchmarks cyber et performance.
Scores et métriques enregistrés en base.

Attribuer chaque résultat et chaque responsabilité au bon projet.

Exposer trois points d'entrée documentés

Contrat versionné dans docs/block2/openapi.yaml.

ÉTAT DE CONFIGURATION

GET /api/v1/ai/health/
Public.
Indique la configuration.
Ne prouve pas un appel réussi au fournisseur.

MÉTADONNÉES

GET /api/v1/ai/configuration/
Authentifié.
Modèles et limites utiles.
Aucune clé ni prompt.

TOUR DE JEU

POST /api/v1/games/
{game_id}/turns/
Session + CSRF.
Avance une sauvegarde possédée.

Une configuration valide ne constitue pas une mesure de disponibilité du modèle.

Contrôler avant de solliciter le modèle

La frontière v1 associe identité, propriété et limites.

IDENTITÉ / PROPRIÉTÉ

Session Django.
Recherche par ID + utilisateur.
Partie étrangère ou absente :
même réponse 404.

REQUÊTE

CSRF requis pour le POST.
Taille et longueur bornées.
Choix comparé à la liste serveur
lorsqu'elle est non vide.

QUOTA

Compteur utilisateur en cache.
Dépassement : HTTP 429.
Un cache partagé et sa
concurrence sont à revoir pour
plusieurs instances.

Les tests prouvent des contrôles précis ; ils ne constituent pas un audit complet de sécurité.

L'agent demande des données aux stories Tines

Contribution confirmée : quatre stories avec un contrat d'API précis.

APPLICATION DJANGO

L'analyste LLM dispose d'outils permettant d'appeler les endpoints selon l'entité cyber à examiner.

TINES

Webhook d'entrée



Story dédiée



Interrogation des consoles EDR nécessaires.

RETOUR À L'AGENT

Les données récupérées sont renvoyées à l'appelant.
Contrat et exemple d'échange à joindre.

Ces endpoints exposent des données et des outils ; ils n'exposent pas le modèle lui-même.

Valider la forme et protéger la progression

Les appels au modèle peuvent échouer ou produire une réponse inutilisable.

SORTIES TYPÉES

ChoiceOutput : 3 choix distincts, chacun ≤ 6 mots.
Objectifs et progression : schémas dédiés.

REPRISES

Retry sur erreurs transitoires.
Délais et tentatives bornés.
Après épuisement : erreur contrôlée du service.

ÉTAT DU JEU

Une génération échouée ne doit pas avancer l'état.
Les règles de soin, dégâts et progression restent côté serveur.

Réussite HTTP, validité du schéma et pertinence narrative sont trois vérifications différentes.

Observer disponibilité, qualité et coût

Collecteurs → Prometheus → Grafana ; règles vers Alertmanager.

SERVICE

Nombre d'appels et erreurs.
Histogramme des durées.
Objectifs : 99 % de succès et p95
< 30 s.

QUALITÉ / RAG

Sorties structurées valides ou
invalides.
RAG : résultats, vides, erreurs et
durées de récupération.

CONSOMMATION

Tokens d'entrée / sortie.
Coût estimé avec tarifs configurés.
Labels sans prompts, identités ni
sessions.

Les SLO sont des objectifs ; aucun historique de production n'est présenté ici.

Transformer un signal en action

Règles présentes ; livraison d'une notification externe à démontrer.

DÉTECTER

3 indisponibilités en 10 min.
Latence élevée persistante.
Sortie structurée invalide.
Erreurs de retrieval.

DIAGNOSTIQUER

Identifier modèle et révision.
Comparer erreurs, durée et RAG.
Reproduire avec un cas minimal
sans donnée personnelle.

AMÉLIORER

Corriger prompt ou configuration.
Rejouer les cas de référence.
Comparer avant / après.
Garder un retour arrière.

Alertmanager utilise un récepteur local : aucune notification externe n'a été prouvée.

Exécuter des benchmarks cyber et de performance

Réalisation d'alternance : une application de lancement et de stockage des résultats.

CYBERSÉCURITÉ

Exécution des benchmarks retenus.
Production de scores.
Règles de scoring sans juge humain ni LLM recherchées à la sélection.

PERFORMANCE

Mesures P50, P95, P99.
Vitesse et concurrence.
Définir les unités, le scénario et le nombre de requêtes.

PERSISTANCE

Métriques et résultats en BDD.
Joindre une exécution réelle, son contexte et les résultats correspondants.

Les tests du logiciel et les évaluations des modèles restent deux preuves distinctes.

Présenter un run du modèle disponible

Famille Qwen ; référence exacte et résultats à insérer depuis les preuves.

CYBER

Benchmark et version.
Score obtenu et unité.
Nombre de cas.
Mécanisme de scoring retenu.

PERFORMANCE

P50 / P95 / P99.
Vitesse et unité.
Concurrence exercée.
Charge, erreurs et durée du test.

INTERPRÉTATION

Ce que le run démontre.
Ses limites.
Décisions possibles pour l'usage.
Aucun classement multi-modèles.

Les runs existent selon le candidat ; aucune valeur n'est recopiée avant réception des pièces.

Automatiser les contrôles avant livraison

Workflow Block 2 AI component versionné dans GitHub Actions.

QUALITÉ

Dépendances verrouillées.
Lint et checks Django.
Tests + seuil de couverture 55 %.
RAG dry-run + dataset offline.

ARTEFACT

Validation des configurations de monitoring.
Build Docker tagué SHA Git.
Smoke test HTTP /health.

ÉVALUATION LIVE

Déclenchement manuel.
Environnement ai-evaluation.
Clé protégée.
Rapport conservé comme artefact.

Le workflow est présent ; aucun succès GitHub distant n'a été vérifié pour ces slides.

Promouvoir un artefact, prévoir le retour arrière

Procédure documentée ; déploiement réel encore à prouver.

PROMOTION

Revoir les tests et le rapport IA.
Publier l'image exacte.
Déployer son digest en staging.
Vérifier santé et parcours.

TRAÇABILITÉ

Révision Git et dataset.
Modèle et paramètres.
Prompts versionnés.
Collection RAG identifiée.
Conserver les rapports.

RETOUR ARRIÈRE

Redéployer le digest précédent.
Restaurer sa configuration.
Revenir à la collection RAG prévue.
Rejouer santé et smoke tests.

Un digest fixe le conteneur ; il ne fige pas à lui seul le comportement d'un fournisseur distant.

Montrer une preuve par réalisation

Préparer les contrats, les résultats et la traçabilité.

API DU JEU

Montrer la frontière authentifiée et un contrôle d'accès.
Tests locaux disponibles dans le dossier initial.

OUTILS TINES

Un contrat réel.
Une story et son parcours EDR.
Une requête / réponse anonymisée.
Contribution personnelle délimitée.

BENCHMARKS

Une campagne d'évaluation.
Résultats cyber et performance.
Enregistrement en base.
Interprétation des écarts.

La livraison continue et l'alerte restent des sujets distincts des campagnes de benchmarks.

Écarts repérés entre contrat et code

Points identifiés à la lecture ; aucune modification applicative dans cette livraison.

OPENAPI

La liste security encode session OU CSRF, alors que la vue exige les deux.
Réunir les exigences dans le contrat.

ENTRÉES

Le contrat interdit les champs supplémentaires ; la vue ne les rejette pas explicitement.
Un JSON non objet reste à tester.

CHOIX

La comparaison est conditionnée à une liste serveur non vide.
Définir et tester le comportement quand elle est vide.

Conserver ces réserves dans l'argumentaire de sécurité.

Assembler les pièces sans mélanger les projets

Sources d'alternance à joindre ; code du jeu déjà disponible.

E2

Matrice des benchmarks.
Critères et exclusions.
Restitution de veille.
Modèles et recommandation.

E3 · ENTREPRISE

Code et commande du runner.
Schéma BDD et résultats.
Contrat Tines et story.
Tests d'intégration disponibles.

E3 · JEU

API et tests.
Configuration / RAG.
Métriques et workflow.
Limites du dossier initial
conservées.

Une campagne de test n'est pas une surveillance continue ni une livraison.

Défendre le protocole et les interfaces

Questions probables sur les nouveaux travaux.

SANS JUGE ?

Quel mécanisme donne le score ?
Que mesure-t-il vraiment ?
Quels biais et quels cas non couverts ?

COMPARAISON ÉQUITABLE ?

Versions, charge et paramètres identiques ?
Combien de cas / répétitions ?
Quel traitement des erreurs ?

TINES ET L'AGENT ?

Quel contrat ?
Qui peut appeler quoi ?
Comment isoler les clients ?
Quelle part as-tu développée ?

Une automatisation du scoring ne garantit pas à elle seule la validité de l'évaluation.